

# Bounded Context IAM

FullTank Platform | IAM legacy v1

## Documento técnico

Este informe y sus diagramas describen la parte legacy v1 de IAM. El modelo v2 incluye Organization y Membership para resolver el tenant; ver docs/api-ledger/T04-A-organization-membership.md y T04-B-onboarding-invitations.md. La organización sigue las capas Domain, Application, Infrastructure e Interfaces.

## Estado

IAM ya está implementado: autenticación JWT, usuarios, roles, compañías compradoras/proveedoras, ownership de recursos y recuperación de contraseña con token de un solo uso. El alta crea usuario y compañía en una transacción y no permite que el cliente elija IDs de compañías existentes.

## Capacidades principales

| Clase / componente | Tipo               | Propósito                                             |
|--------------------|--------------------|-------------------------------------------------------|
| Inicio de sesión   | REST               | sign-in devuelve JWT, roles y company/provider ID.    |
| Registro           | REST + transacción | sign-up crea usuario y perfil empresarial nuevo.      |
| Recuperación       | REST + SMTP        | request/confirm con hash, expiración y consumo único. |
| Autorización       | Security           | Bearer filter y CurrentUserAccess.                    |
| Directorio         | REST               | Usuarios y compañías para consultas protegidas.       |

# Figura 1

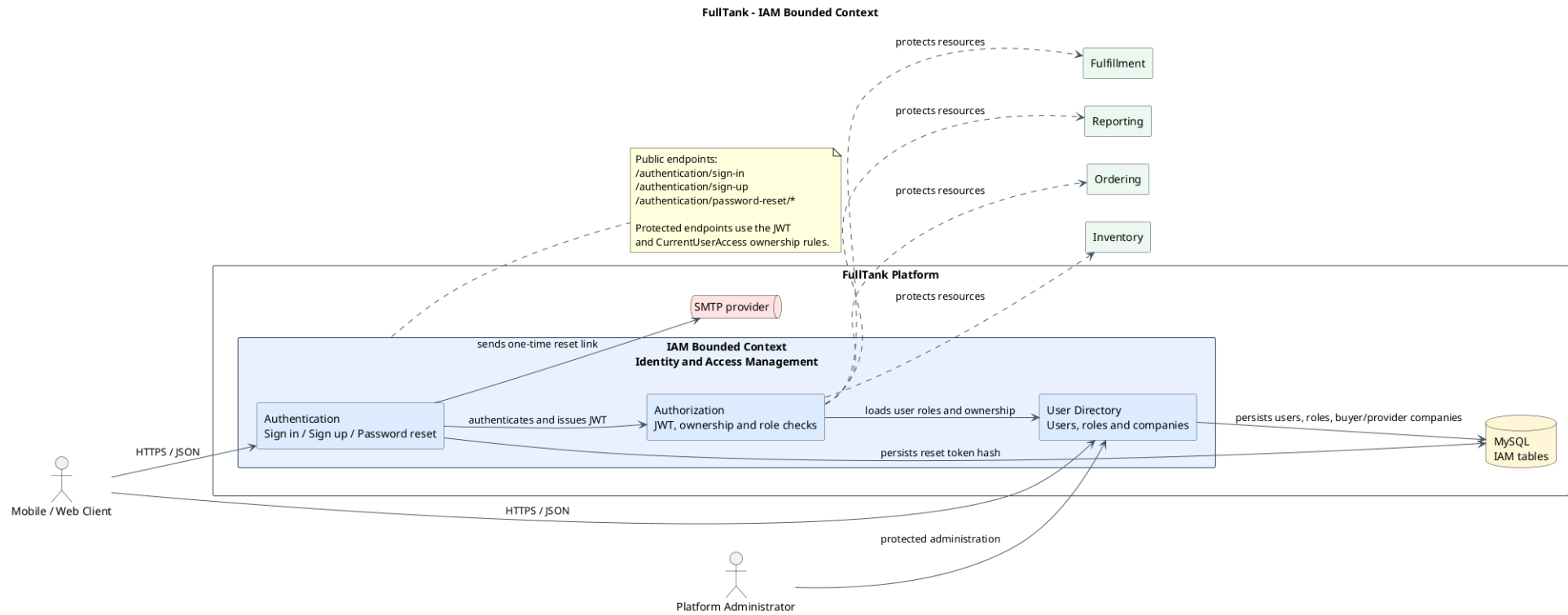


Figura 1. Límites, dependencias y relaciones del bounded context IAM.

# Figura 2

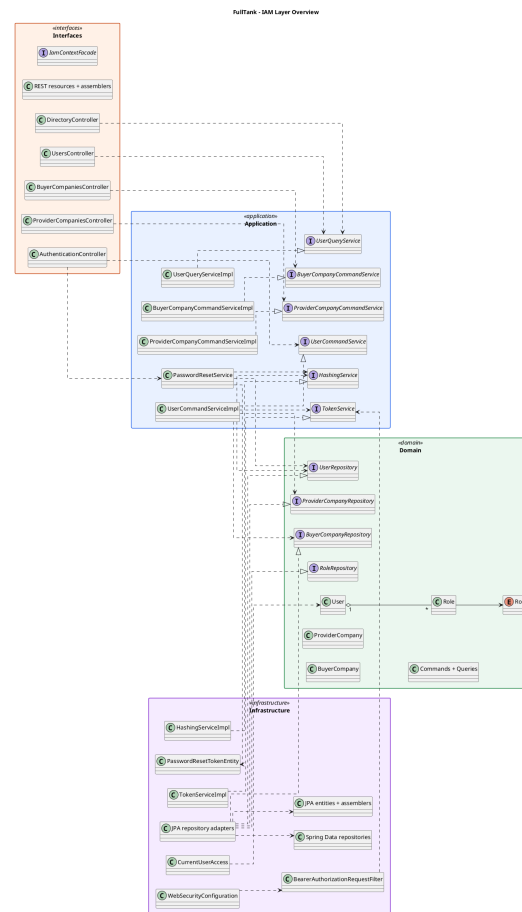


Figura 2. Vista de capas y componentes principales.

# Domain Layer

## Elementos del dominio

| Clase / componente            | Tipo                | Propósito                                             |
|-------------------------------|---------------------|-------------------------------------------------------|
| User                          | Aggregate Root      | Identidad autenticable, roles y vínculo con compañía. |
| BuyerCompany                  | Aggregate Root      | Empresa compradora y sus datos de contacto.           |
| ProviderCompany               | Aggregate Root      | Empresa proveedora y combustibles ofrecidos.          |
| Role                          | Entity              | Rol persistente asociado a un usuario.                |
| Roles                         | Value Object / enum | ROLE_BUYER y ROLE_PROVIDER.                           |
| SignUpCommand / SignInCommand | Command             | Casos de uso de registro e inicio de sesión.          |
| Create*CompanyCommand         | Command             | Creación de perfiles de empresa.                      |
| Get*Query                     | Query               | Consultas de usuarios y compañías.                    |
| *Repository                   | Repository Port     | Puertos de persistencia del dominio.                  |

# Application Layer

## Servicios, handlers y puertos

| Clase / componente        | Tipo                | Propósito                                         |
|---------------------------|---------------------|---------------------------------------------------|
| UserCommandService / Impl | Command Service     | Sign-in, sign-up, hashing, roles y vínculos.      |
| UserQueryService / Impl   | Query Service       | Consulta de usuarios para directorio y seguridad. |
| BuyerCompany*Service      | Command / Query     | Casos de uso de compañía compradora.              |
| ProviderCompany*Service   | Command / Query     | Casos de uso de compañía proveedora.              |
| RoleCommandServiceImpl    | Command Handler     | Siembra de roles base.                            |
| PasswordResetService      | Application Service | Token hash, correo y cambio de contraseña.        |
| HashingService            | Outbound Port       | Contrato de BCrypt.                               |
| TokenService              | Outbound Port       | Contrato de JWT.                                  |

# Infrastructure Layer

## Adaptadores, persistencia y seguridad

| Clase / componente                    | Tipo                   | Propósito                                |
|---------------------------------------|------------------------|------------------------------------------|
| *RepositoryImpl                       | Repository Adapter     | Adaptan Domain a Spring Data JPA.        |
| *PersistenceEntity                    | JPA Entity             | Tablas users, roles y compañías.         |
| PasswordResetTokenEntity              | JPA Entity             | Hash, usuario y expiración del reset.    |
| *PersistenceRepository                | Spring Data JPA        | Consultas de persistencia.               |
| PasswordResetTokenRepository          | Spring Data JPA        | Tokens válidos, bloqueo y consumo único. |
| *PersistenceAssembler                 | Mapper                 | Conversión Domain <-> JPA.               |
| WebSecurityConfiguration              | Security Configuration | Endpoints públicos, JWT y stateless.     |
| BearerAuthorizationRequestFilter      | JWT Filter             | Carga autenticación desde Bearer token.  |
| UserDetailsServiceImpl                | Security Adapter       | Traduce usuario a Spring Security.       |
| CurrentUserAccess                     | Ownership Policy       | Roles y ownership por recurso.           |
| HashingServiceImpl / TokenServiceImpl | Adapters               | BCrypt y JWT concretos.                  |

# Interfaces Layer

## REST, DTOs y ACL

| Clase / componente            | Tipo            | Propósito                              |
|-------------------------------|-----------------|----------------------------------------|
| AuthenticationController      | REST Controller | Sign-in, sign-up y password reset.     |
| UsersController               | REST Controller | Directorio administrativo de usuarios. |
| BuyerCompaniesController      | REST Controller | Operaciones de compradores.            |
| ProviderCompaniesController   | REST Controller | Operaciones de proveedores.            |
| DirectoryController           | REST Controller | Consultas de directorio.               |
| *Resource                     | DTO record      | JSON de entrada/salida y validación.   |
| *ResourceFromEntityAssembler  | Assembler       | Domain -> REST.                        |
| *CommandFromResourceAssembler | Assembler       | REST -> Application command.           |
| IamContextFacade              | ACL             | Acceso controlado para otros módulos.  |

# Seguridad y verificación

- El secreto JWT es obligatorio mediante AUTHORIZATION\_JWT\_SECRET.
- Los endpoints de autenticación y documentación son públicos; el resto requiere autenticación.
- Compradores y proveedores solo acceden a recursos de su compañía o proveedor.
- El reset responde de forma neutra para cuentas existentes y desconocidas.
- El token se guarda como SHA-256, expira en 30 minutos y se elimina al consumirse.
- SMTP se configura con SMTP\_HOST, SMTP\_PORT, SMTP\_USERNAME, SMTP\_PASSWORD, SMTP\_AUTH, SMTP\_STARTTLS y MAIL\_FROM.

## Artefactos reproducibles

PlantUML está incluido en tools/plantuml/plantuml.jar y Structurizr CLI en tools/structurizr/structurizr.sh. Los fuentes son iam-bounded-context.puml, iam-layer-overview.puml, iam-class-layer.puml e iam-structurizr.dsl.

## Comandos:

```
java -jar tools/plantuml/plantuml.jar -tpng -tsvg -o rendered docs/diagrams/iam-bounded-context.puml
tools/structurizr/structurizr.sh validate -workspace docs/diagrams/iam-structurizr.dsl
```